

HOW TO BUILD CYBERSECURITY METRICS AND EXECUTIVE REPORTING

A concise, practical implementation manual

Alberto (Al) Leiva

Version 1.0 - July 2026

Purpose

Use this manual for lawful, authorized, defensive work. Adapt controls to organizational risk, legal obligations, accessibility needs, and available resources.

Measurement strategy

- Start with business decisions, risk questions, and desired outcomes.
- Define audience, purpose, owner, formula, source, frequency, target, threshold, and limitations for every metric.
- Use a balanced set of leading, lagging, coverage, quality, risk, and resilience measures.

Data quality and governance

- Assign data owners and validate completeness, consistency, timeliness, and lineage.
- Automate collection where practical but retain human review.
- Do not compare teams or periods when definitions changed without explanation.

Operational metrics

- Track control coverage, vulnerabilities, identity risk, detection quality, incidents, recovery, suppliers, cloud, awareness, and exceptions.
- Use rates and denominators rather than raw counts alone.
- Segment by criticality, exposure, business service, and trend.

Risk and outcome metrics

- Connect technical conditions to probable business impact.
- Show residual risk, concentration, control effectiveness, and demonstrated recovery capability.
- Avoid false precision when uncertainty is high.

Executive reporting

- Lead with decisions required, changes in exposure, major exceptions, and resource implications.
- Use concise trends, thresholds, and plain language.
- Separate facts, estimates, assumptions, and management acceptance.

Targets and incentives

- Set targets based on risk appetite and realistic capability.
- Avoid targets that encourage hiding incidents or closing findings prematurely.
- Review whether a metric drives the intended behavior.

Roadmap and sample dashboard

- Days 1-30: define audiences, questions, owners, and ten core measures. Days 31-60: validate sources, thresholds, and reporting. Days 61-90: automate, review behavior, and retire low-value metrics.
- Recommended dashboard: top risks, risk trend, critical control coverage, material incidents, overdue high-risk actions, recovery testing, supplier concentration, and decisions needed.

Implementation checklist

- ☐ Owner assigned
- ☐ Scope approved
- ☐ Inventory complete
- ☐ Risks prioritized
- ☐ Policies documented
- ☐ Controls implemented
- ☐ Evidence retained
- ☐ Exceptions expire
- ☐ Testing completed
- ☐ Management review recorded

Official references

- NIST SP 800-55 Volume 2: <https://csrc.nist.gov/pubs/sp/800/55/v2/final>
- NIST Cybersecurity Measurement: <https://www.nist.gov/cybersecurity-measurement>
- NIST CSF 2.0: <https://www.nist.gov/cyberframework>

License

Copyright © 2026 Alberto (Al) Leiva. Licensed under CC BY-NC-SA 4.0.